

BROKEN LINK HIJACKING (BLH)

INTRODUCTION

In the evolving landscape of web security, attackers are continuously identifying and exploiting overlooked weaknesses. One such vulnerability is Broken Link Hijacking (BLH) — a subtle yet impactful security issue often ignored during traditional penetration testing and security audits. This report aims to explain what Broken Link Hijacking is, the consequences it can lead to, ways to mitigate it, and how to use the Burp Suite extension that automates its detection.

1. What is Broken Link Hijacking (BLH)?

Broken Link Hijacking occurs when a website or application includes references to external domains, scripts, images, APIs, or services that are no longer registered or valid. If these domains are expired or mistyped, an attacker can register them and serve malicious content in place of the original resource.

How it works:

- A website includes a JavaScript or image file from `http://cdn.example-old.com/file.js`.
- That domain `cdn.example-old.com` is no longer owned.
- An attacker notices this and registers the domain.
- Now the attacker can serve malicious scripts to users visiting the legitimate website.

2. What is the Impact and Mitigation?

Impact:

- Cross-Site Scripting (XSS): Attacker can inject malicious JS into the original website.
- Credential Theft: Hijacked content can redirect users to phishing pages.

- Brand Damage: Hosting spam or defacement on a hijacked domain associated with your website.
- Malware Distribution: Deliver payloads via hijacked CDN or media files.
- SEO Poisoning: Search engines may penalize your domain if hijacked links spread malware.

Mitigation Techniques:

- Regular Asset Audits: Identify and remove unused or broken external resources.
- DNS Monitoring: Track and alert on expired or unresolvable domains.
- Subresource Integrity (SRI): Use SRI to ensure the integrity of externally loaded scripts.
- Use Self-hosted Resources: Avoid relying on 3rd-party scripts where possible.
- Content Security Policy (CSP): Limit the domains from which resources can be loaded.
- Penetration Testing: Include BLH checks in security assessments.

3. Explanation of the BLH Extension in Burp Suite

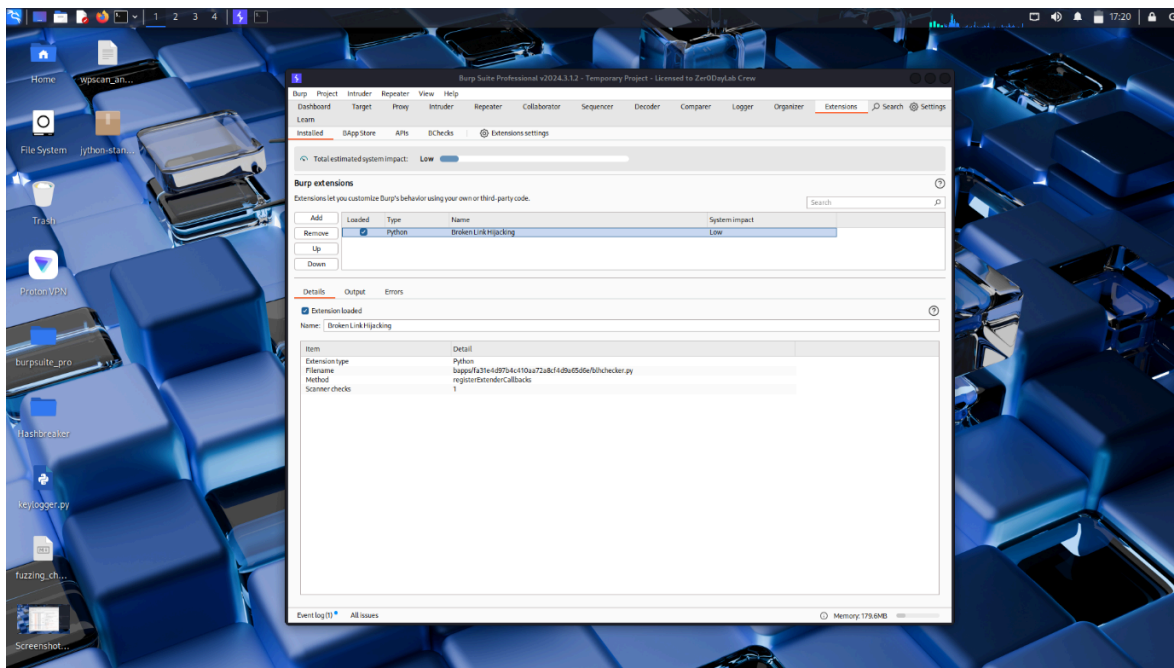
PortSwigger provides a Burp Suite extension named Broken Link Hijacking developed by Arbaaz Hussain, available in the official BApp Store.

Extension Overview:

- Name: Broken Link Hijacking
- Purpose: To passively scan HTTP responses and detect references to broken external domains.
- Functionality:
 - Scans for unreachable or expired domains in HTTP responses.
 - Highlights potential BLH opportunities for testers.

- o Helps in identifying resources that may be susceptible to hijacking.
- System Impact: Low (Passive analysis only)

Screenshot of Installed Extension:



CONCLUSION

Broken Link Hijacking is an often overlooked but highly dangerous vulnerability that can silently impact a website's security posture. Through the use of automated tools like the Broken Link Hijacking Burp Extension, security professionals can effectively detect and mitigate such flaws. Organizations must make it a part of their regular security audits and take proactive steps in maintaining the integrity of linked resources. Ignoring these small gaps can lead to serious compromises, reputational loss, and data breaches.